Smiles S.A.

RELATÓRIO DE AUDITORIA
N°. 2016-1/3431

Assunto: AIC - COBIT - S.DS5.9.B - Gestão de Antivírus

Período da Auditoria:
29/06/2016 a 01/07/2016

Smiles S.A.

ÍNDICE

1 INTRODUÇÃO 3
2 OBJETIVO 3
3 ESCOPO 3
4 CONCLUSÃO 3
5 DETALHAMENTO DE RISCOS E CONTROLES 4
5.1 SDS5.9.B.R01.SDS5.9.B.C01 4
5.1.1 SDS5.9.B.C01 4
5.2 SDS5.9.B.R02.SDS5.9.B.C02 5
5.2.1 SDS5.9.B.C02 5

Smiles S.A.

1 INTRODUÇÃO

Auditoria no processo S.DS5.9.B - Gestão de Antivírus.

2 OBJETIVO

Nosso trabalho teve como objetivo a verificação quanto à efetividade dos controles do Processo do Cobit - Gestão de Antivírus para mitigar os riscos vinculados com as atividades desse Processo, no contexto da avaliação da Administração (testes da Administração) para certificação 404-SOX.

3 ESCOPO

Verificar se as máquinas selecionadas para teste estão com o antivírus atualizado e os controles que mitigam os riscos estão sendo executados.

4 CONCLUSÃO

Os controles testados, definidos na Matriz de Riscos e Controles, não estão sendo executados de forma efetiva. Nossos testes revelaram pontos e deficiências relevantes que colocam em risco o ambiente de controles gerais da área de TI, tais como:

. O controle S.DS5.9.B.C01 referente ao acompanhamento das atualizações do antivírus está mapeado para ser executado semestralmente. Sendo que até 30 de junho de 2016, nenhum acompanhamento foi realizado.

. Não existe software antivírus instalado nos servidores do Data Center da Smiles.

. Não existe nenhum acompanhamento formal e periódico com relação a atualização do software antivírus nas estações de trabalho.

. Nosso teste de inspeção física realizado por amostragem identificou 01 (uma) estação de trabalho com DAT desatualizada (há mais de um ano) e 02 (duas) estações de trabalho que não possuíam o antivírus McAfee instalado.

. A matriz de risco e o procedimento deste processo estão resumidos de uma forma que dificulta o seu adequado e total entendimento.

. O controle S.DS5.9.B.C02 sobre a coleta e divulgação do indicador não está sendo executado.

5 DETALHAMENTO DE RISCOS E CONTROLES

5.1 SDS5.9.B.R01.SDS5.9.B.C01

Descrição Risco:	Exposição de dados sensíveis e violações de requisitos legais e regulatórios, sistemas e dados propenso a taques de vírus e contra medidas inefetivas.

5.1.1 SDS5.9.B.C01

Descrição Controle:	Revisão dos relatórios com as informações semestral dos índices de atualização do antivírus em servidores e estações de trabalho.
Efetividade:	Inefetivo

Ponto:

NCONF-01 O controle S.DS5.9.B.C01 referente ao acompanhamento das atualizações do antivírus está mapeado para ser executado semestralmente. Entendemos que está frequência é muito longa e dificulta a identificação e correção de problemas relacionados a atualização da solução de antivírus.

NCONF-02 Verificamos que não existe antivírus instalado nos servidores do Data Center da Smiles.

NCONF-03 A área de TI da Smiles não efetua nenhum acompanhamento formal e periódico com relação a atualização do software antivírus nas estações de trabalho.

NCONF-04 Em nosso teste de inspeção física verificamos que das 11 (onze) estações de trabalho selecionadas para análise, 03 (três) estações se encontravam com as seguintes irregularidades: 01 (uma) estação de trabalho com DAT desatualizada (há mais de um ano) e 02 (duas) estações de trabalho não possuíam o antivírus McAfee instalado.

NCONF-05 A matriz de risco e o procedimento deste processo (Gestão de Antivírus) estão resumidos de uma forma que dificulta o seu adequado entendimento. Adicionalmente, verificamos não existe uma referência entre o procedimento e a matriz de risco.

Recomendação:

NCONF-01 Recomendamos que o controle S.DS5.9.B.C01 seja executado mensalmente para que a analise e a tomada de decisão sejam efetuadas de forma mais tempestiva.

NCONF-02 Recomendamos que a área de Infraestrutura Smiles efetue a instalação de antivírus nos servidores que se encontram no Data Center Smiles evitando exposição de dados e ameaças de programas maliciosos.

NCONF-03 Recomendamos que a área de TI da Smiles estabeleça mecanismos para monitorar e corrigir as estações de trabalho que não estão sendo automaticamente atualizadas pelo software antivírus. Tal recomendação visa não somente avaliar o percentual de estações de trabalho protegidas, mas principalmente minimizar a ameaça de infecção de programas maliciosos. Deve ser criado um controle chave na matriz de risco deste processo para acompanhamento das ações a serem tomadas com relação as estações de trabalho que não estão sendo atualizadas automaticamente.

NCONF-04 Recomendamos que seja efetuada a atualização e a instalação do software antivírus da McAfee para as seguintes estações de trabalho listadas a seguir:

Patrimônio	Nome	Setor	Resultado da análise
297	João Paulo Andrade	CRM	Estação de trabalho se encontra com o antivírus (DAT) desatualizado há mais de 01 ano.
003	Jonathas Souza	TI - Operação	Estação de trabalho não possui o Antivírus McAffe instalado.
295	Luiz Savioli	TI - Operação	Estação de trabalho não possui o Antivírus McAffe instalado.

Recomendamos ainda que a área de TI identifique os motivos pelos quais essas estações não estão com a solução de antivírus instalada ou o antivírus está desatualizado, para que sejam tomadas medidas no sentido de aprimorar os controles relativos a este processo.

NCONF-05 Recomendamos que esse procedimento seja aprimorado e descrito de uma forma mais detalhada, demonstrando como serão realizados os monitoramentos e acompanhamentos sobre atualização de antivírus para as estações de trabalho e servidores, detalhando de que forma a área de TI da Smiles deverá atuar nesse processo, assim como o risco de novas estações de trabalho ou de equipamentos em manutenção não possuírem antivírus instalado e atualizado.

5.2 SDS5.9.B.R02.SDS5.9.B.C02

Descrição Risco: Não ocorrer a divulgação de indicadores do processo

5.2.1 SDS5.9.B.C02

Descrição Controle: Quantidade de incidentes causados pela não atualização de patches de segurança.

Efetividade: Inefetivo

Ponto:

NCONF-06 O controle S.DS5.9.B.C02 sobre a coleta e divulgação do indicador não está sendo executado. Verificamos também que o indicador definido neste procedimento está relacionado com a atualização de Patch (e não com antivírus), conforme descrito no texto da matriz de risco reproduzido a seguir:

- "*Quantidade de incidentes causados pela não atualização de* ***patches de segurança***"

PA-01 Existem indicadores críticos para o negócio que não estão sendo capturados pela área de TI.

Recomendação:

NCONF-06 Recomendamos que o controle sobre a coleta e divulgação do indicador seja revisto e passe a ser executado periodicamente.

PA-01 Aprimorar os indicadores deste processo, para que os mesmos auxiliem a área de TI na identificação e correção de eventuais desvios. A título de sugestão listamos os seguintes indicadores:

- Percentual de máquinas elegíveis que foram atualizadas no período
- Percentual de máquinas sem o agente instalado
- Percentual de máquinas com DATs desatualizadas
- Percentual de maquinas sem antivírus instalado.

Smiles S.A.

Envolvidos na Auditoria:

_____
Delio Goldner
Revisor

_____
Marcio Mendes
Revisor

_____
Andre Luis Gonçalves Fernandes
Auditor Responsável

_____
Juliana Genio Dantonio
Aprovador 1a Alçada